Problems met while building the cases, and what to add

Everything below came up while driving the board through the two worked cases (the Okta vishing wave and the SafePay ransomware advisory) and the feature run. Each item says what happened, why it matters to an analyst, and what would fix it. Items marked **fixed** are already changed in this repo.

Bugs found (fixed in `src/logic.js`)

1. **Board export, case brief and one-pager crashed when the case had a cluster.** `renderBoard()` drew the cluster rectangles before the canvas context existed. Fixed by drawing them after the context is created and translated. Any case that used "+ Cluster" could not be exported or briefed before this.
2. **The passphrase lock screen crashed on load.** The locked initial state lacked the `extract`, `newFrom`, `newTo` and `newRel` fields that the template reads. Encrypted cases could not be opened again. Fixed by initialising them.

Friction an analyst will hit

3. **Esc does nothing while the cursor is in a text box.** Keyboard shortcuts are suppressed inside inputs, including Esc, so the OSINT workbench, ACH or a modal cannot be closed with Esc straight after typing in them; you have to click Close. Suggest letting Esc through from inputs (it is never used for typing).
4. **Quick-add help text is incomplete.** The box lists `d i h u e n p t c`, but the parser also accepts `m` (email), `w` (wallet), `cve`, `@` (handle), `l` (location), `doc`, `x` (transfer) and `org` (target). Typing `tx …` silently creates a note. Show the full list in the placeholder or a `?` popover, and reject unknown commands with a toast instead of making a note.
5. **Extract IOCs and CSV import do not recognise hostnames or file names.** The SafePay advisory lists hostnames (`WIN-SBOE3CPNAL`) and dozens of file names (`locker.dll`, `sharefinder.ps1`, `Socks_werfault.exe`); none can become indicator cards, so they had to go into a note. Add `hostname` and `filename` indicator kinds (with YARA / Sigma-friendly export) and let Extract pick them up. The CSV importer maps a `hostname` column to the Domain kind, so Windows computer names end up labelled as domains, and it silently skips any value already on the board without saying which ones.
6. **SHA-1 and SHA-256 are both just "hash".** The card does not say which algorithm it holds, and STIX export has to guess from the length. Keep the algorithm on the card and in the pattern.
7. **Extract IOCs does not de-duplicate against the board.** Running it twice on overlapping text creates duplicate cards that then need Merge. Skip values that already exist in the case, or offer "update existing".
8. **CDN and SaaS addresses are not flagged.** Several IPs in the CISA table belong to Cloudflare, GitHub and Google ranges. The board pins them like any other IOC; nothing warns that blocking them would be wrong. An ownership lookup on pin (ASN / org, already available through RDAP in the workbench) with a "shared infrastructure" badge would prevent bad blocklists.

9. **Most OSINT lookups are blocked in the browser.** crt.sh, urlscan, ThreatFox, MalwareBazaar, Wayback and VirusTotal refuse cross-origin requests, so only Google DNS, RDAP and NVD return live; everything else is a launcher link, and VirusTotal shows a captcha when opened. The backend in `BACKEND-SPEC.md` (server-side keys, cached results, enrichment landing as inbox cards) is the real fix; until then a small proxy for the free endpoints would already make the workbench much more useful.
10. **The ATT&CK table is a short local list.** Only about 45 techniques resolve to a name and tactic; `T1569.002`, `T1548.002`, `T1560.001`, `T1048`, `T1490`, `T1218`, `T1134.001` from the SafePay advisory came in as bare IDs, which the kill-chain view cannot lane. Ship the full Enterprise matrix (or fetch it once and cache it) and let the user pick a tactic when the ID is unknown.
11. **The actor library is static and small.** SafePay, Akira, Qilin, Medusa and other current ransomware operations are absent, so the only option was to drop in LockBit as a comparison and stamp it False lead. Let analysts add actors, import them from STIX intrusion-sets, or load a MISP galaxy.
12. **New cards pile up in the middle of the board.** Pinning twenty extracted indicators produces a stack that must be dragged apart by hand. Place new cards in a free spot (the cluster code already has `freeSpot`), or offer "arrange by type" and "arrange by cluster".
13. **Moving a card does not bring its cluster along, and clusters are geometric only.** Membership is "centre inside the rectangle", so a card that drifts out silently leaves the cluster, and resizing can capture unrelated cards. Explicit membership (drag onto cluster, listed in the panel) would be more predictable.
14. **Thread suggestions only look at shared tags and tokens.** They did not suggest linking the soc.dll hash to its C2 address even though the advisory ties them together. Suggestions from the OSINT results (resolutions, certificate SANs, same ASN) and from indicators appearing in the same source card would catch more.
15. **Events have a day but no time.** The SafePay timeline (16:05 ET drain, 17:01 freeze, …) in the sample case can only be ordered by day. Add an optional time to event cards and sort the timeline by it.
16. **Pictures live inside the case as data URLs.** Images are shrunk to 900 px and embedded, so a case with maps and captures grows quickly; `localStorage` has a hard ceiling of a few megabytes per origin and snapshots copy the images again. Store files separately (IndexedDB now, object storage with the backend) and keep only a reference on the card.
17. **No case-level metadata beyond title and TLP.** There is no owner, no tags or sector, no related-case links and no "source advisory" field, so the case list cannot be filtered or grouped. Add a small header block and show it in the case switcher.
18. **Search has no filters and no scope.** Cross-case search is useful, but there is no way to search only indicators, only a tag, or only the current case, and no saved searches. Add type / tag / case filters and remember recent queries.
19. **Transfers need addresses to be useful.** The transfer card links to a block explorer only when a tx hash or address is present; public advisories often give amounts without addresses. Allow an amount-only transfer to still appear in the brief's financial summary, and let several transfers roll up into a total.
20. **Merge is manual, one card at a time.** After an actor drop-in or a second extraction there can be many duplicates. A "find duplicates" button (same value, same technique ID, same title) with a merge-all review would save time.
21. **ACH has no scoring summary.** Cells can be marked, and the count of inconsistencies is shown per hypothesis, but there is no weighting by evidence grade and the matrix is not in the case brief. Weight by Admiralty grade and print the matrix.

22. **The request letter cannot be sent or tracked.** Open letter / Copy text is all there is; the Requests count in the audit is not tied to a card. Record each generated request as a task with a reference number and a due date.
23. **"Analyse with Claude" only works in the Claude app preview.** Elsewhere the button just shows a toast. With a backend key (see `/v1/ai/assess` in the spec) it could run anywhere, and the assessment could be stored on the card instead of only shown.
24. **Mobile is read-mostly.** Narrow screens get a list, but cards cannot be arranged or connected and the OSINT workbench is cramped. Fine for review; say so in the UI.
25. **Single-letter shortcuts fire while a button has focus.** After clicking a toolbar button, pressing `t` or `k` toggles a layout even though the user is not "on the board". Scope shortcuts to the board or require focus there.

Things that worked well and are worth keeping

- Extract IOCs with defanged input, the OSINT workbench's type detection, the Audit tab's backlog, snapshots with diff, playback, the brief and one-pager, and the STIX round trip all behaved as designed and needed no workaround.
- RDAP and NVD lookups return real data from the browser without keys; the Vilnius / Falkenstein locations on the SafePay board and the CVE descriptions came from them.